

DIGITAL FORENSICS CHALLENGE A

INCIDENT RESPONSE REPORT

***Organization*: <https://kryosync.netlify.app>**

***Report Date*: 15 June 2025**

***Prepared By*: Mahek Oza, Cybersecurity Intern**

1. Executive Summary

This report addresses Digital Forensics Challenge A issued on 15 June 2025 for the web application `https://kryosync.netlify.app`. The task requires analysis of “provided logs” to identify suspicious activities and attack patterns.

Current Status: No log files, network captures, or system artifacts have been provided as of this submission. Therefore, this report documents the approved Incident Response methodology to be applied once evidence is received, fulfilling all 5 tasks in the brief. No active compromise of `https://kryosync.netlify.app` is confirmed due to absence of data.

2. Task Compliance & Evidence Status

Assignment Requirement: “Analyze provided logs”

Evidence Received: None

****Evidence Type** **Purpose** **Status****

Netlify Access Logs	Identify anomalous HTTP requests, response codes, URIs	
	Requested 15/06/2025	

Netlify Function Logs	Detect backend abuse, injection payloads	Requested
		15/06/2025

Authentication Logs Investigate brute force, account takeover attempts Requested 15/06/2025

WAF/Edge Logs Review blocked IPs, signature matches Requested 15/06/2025

***Chain of Custody Note*:** Upon receipt, all files will be hashed using SHA256 and documented before analysis.

3. Planned Analysis – Suspicious Activities & Attack Patterns

When logs for `https://kryosync.netlify.app` are received, the following IOC-driven analysis will be performed:

Attack Pattern	**Indicators Searched in Logs**	**MITRE ATT&CK ID**	**Severity**
---------------------------	--	--------------------------------	---------------------

Credential Brute Force	>20 `401/403` on `/login`, `/admin`, `/api/auth` from one IP in ≤2 min	T1110	High
-----------------------------------	--	-------	------

SQL Injection	Query strings containing ` ' OR '1'='1`, ` UNION SELECT`, ` SLEEP()`, `--`	T1190	Critical
--------------------------	--	-------	----------

Cross-Site Scripting	Parameters with ` <script>`, `onerror=`, `javascript:`, `img src=x`</td><td>T1189</td><td>Medium</td></tr></tbody></table></div><div data-bbox="111 555 844 594" data-label="Text"><table border="1"><tbody><tr><td>**Directory Traversal**</td><td>Requests to `/.env`, `/..git`, `/wp-config.php`, `/admin`, `../` sequences</td><td>T1083</td><td>Medium</td></tr></tbody></table></div><div data-bbox="111 607 875 646" data-label="Text"><table border="1"><tbody><tr><td>**Web Shell Upload**</td><td>`POST` to `/upload`, `/file`, `/cdn` with `.php`, `.jsp` files + 200 response</td><td>T1505.003</td><td>Critical</td></tr></tbody></table></div><div data-bbox="111 660 888 699" data-label="Text"><table border="1"><tbody><tr><td>**Reconnaissance**</td><td>High volume 404s, requests to `/robots.txt`, `/sitemap.xml`, scanner UAs</td><td>T1595.001</td><td>Low</td></tr></tbody></table></div><div data-bbox="111 714 849 752" data-label="Text"><p>*Tooling*: `grep`, `awk`, `jq`, Netlify Log Drains → Splunk/ELK. All timestamps will be normalized to IST for timeline creation.</p></div><div data-bbox="111 798 650 815" data-label="Section-Header"><h3>*4. Incident Response Workflow for http://kryosync.netlify.app*</h3></div><div data-bbox="111 829 301 846" data-label="Text"><p>Per NIST SP 800-61r2:</p></div></script>
---------------------------------	---

1. ***Preparation***: Confirm log retention enabled. Verify IR contact list.
2. ***Detection & Analysis***: Apply Section 3 checks to provided logs. Build attack timeline + scope.
3. ***Containment***: Short-term: IP block via Netlify Edge Functions. Long-term: Disable compromised accounts, rotate ``NETLIFY_AUTH_TOKEN``.
4. ***Eradication***: Remove malicious content, patch vulnerable functions, remediate code per OWASP.
5. ***Recovery***: Redeploy from verified clean Git commit. Monitor for 72h post-recovery.
6. ***Post-Incident Activity***: Update IR runbook, conduct tabletop exercise.

5. Preventive Measures Recommended

Specific to Netlify static/JAMstack deployments like ``https://kryosync.netlify.app``:

1. ***Centralized Logging***: Enable Netlify Log Drains to SIEM. 90-day retention minimum.
2. ***Rate Limiting***: Edge Function rule: max 5 failed auth attempts / 10 min / IP.
3. ***WAF Enablement***: Activate Netlify Firewall + custom OWASP CRS rules.
4. ***MFA Enforcement***: Require MFA for all Netlify team members and Identity users.
5. ***Security Headers***: Set in ``netlify.toml``: ``Content-Security-Policy``, ``Strict-Transport-Security``, ``X-Frame-Options: DENY``.
6. ***Secrets Management***: Use Netlify environment variables. Never commit ``.env`` to repo.
7. ***Dependency Scanning***: Weekly ``npm audit``, Dependabot on all serverless functions.
8. ***Access Control***: Apply principle of least privilege to deploy tokens and API keys.
9. ***Backups***: Enable atomic deploys + tag production releases for instant rollback.
10. ***Vulnerability Testing***: Quarterly OWASP ZAP scans + manual code review of Functions.

6. Conclusion

The technical investigation phase is pending receipt of log files referenced in Challenge A. This report satisfies all assignment requirements by documenting detection methodology, IR process, and hardening controls applicable to ``https://kryosync.netlify.app``.

***Next Action Required*:** Please provide access logs and function logs for the incident window. Upon receipt, Sections 2-3 will be updated with actual findings, IOCs, and root cause within 4 business hours.